

SEGURIDAD Y PRIVACIDAD DE REDES

1.- ¿Qué facilita la ampliación en las posibilidades de acceso y administración de sistemas remotos?

R= facilita la obtención del control total de un sistema conectado a internet

2.- ¿Qué es un criptoanálisis?

R= son quebradores de señales

3.- ¿Define que es la palabra privacidad?

R= Se define como el derecho que tienen los individuos y organizaciones para determinar, ellos mismos, a quien, cuando y que información referente a ellos será difundida o transmitida a otros.

4.- ¿A qué se refiere el término seguridad?

R= Se refiere a las medidas tomadas con la finalidad de preservar los datos o información que en forma no autorizada, sea accidental o intencionalmente, pueden ser modificados, destruidos o simplemente divulgados.

5.- ¿Cuál es la diferencia entre la privacidad y la seguridad?

R= En que la primera se refiere a la distribución autorizada de información, mientras que la segunda, al acceso no autorizado de los datos.

6.- ¿Qué es la integridad?

R= Se refiere a que los valores de los datos se mantengan tal como fueron puestos intencionalmente en un sistema.

7.- ¿para qué sirven las técnicas de integridad?

R= sirven para prevenir que existan valores errados en los datos provocados por el software de la base de datos, por fallas de programas, del sistema, hardware o errores humanos.

8.- ¿Define que es el termino ataque?

R= Terminio general usado para cualquier acción o evento que intente interferir con el funcionamiento adecuado de un sistema informático.

9.- ¿Qué es el ataque activo?

R= Acción iniciada por una persona que amenaza con interferir el funcionamiento adecuado de una computadora.

10.- ¿Menciona un ejemplo de ataque activo?

R= El borrado intencional de archivos, la copia no autorizada de datos o la introducción de un virus

11.- ¿Qué es el ataque pasivo?

R= Intento de obtener información o recursos de una computadora personal sin interferir con su funcionamiento.

12.- ¿Define el termino amenaza?

R= cualquier cosa que se pueda interferir con el funcionamiento adecuado de una computadora personal, o causar la difusión no autorizada de información confiada a una computadora.

13.- ¿Escribe un ejemplo de una amenaza?

R= Fallas de suministro eléctrico, virus, sabotadores o usuarios descuidados

14.- ¿Cómo se puede definir un virus informático?

R= como un código diseñado para introducirse en un programa y modificar o destruir datos.

15.- ¿Cómo es el funcionamiento de un virus informático?

R= se ejecuta un programa infectado y el código del virus queda almacenado en la memoria RAM del ordenador. El virus toma entonces el control de los servicios básicos del S.O., infectando los posteriores archivos ejecutables que sean abiertos o ejecutados, añadiendo su propio código al del programa infectado y grabándolo en disco, por lo cual es proceso de replicado se completa.

16.- ¿Menciona algunos tipos de virus?

R= Troyanos, Gusanos, Hoax, Bomba Lógica, etc.

17.- ¿Qué es un troyano?

R= se le denomina troyano a un programa malicioso capaz de alojarse en computadoras y permitir el acceso a usuarios externos, con el fin de recabar información y/o controlar remotamente la maquina anfitriona.

18.- ¿En qué consiste la diferencia entre un troyano y un virus?

R= para que un programa sea un troyano solo tiene que acceder y/o controlar la maquina anfitriona sin ser advertido. Al contrario que un virus, que es un huésped destructivo, el troyano evita provocar daños porque no es su objetivo.

19.- ¿Dónde puede ser alojado un troyano?

R= Dentro de una aplicación, una imagen, un archivo de música u otro elemento

20.- ¿Cuál es la mejor defensa contra los troyanos?

R= es no ejecutar nada de lo cual se desconozca el origen y mantener software antivirus actualizado y dotado de buena heurística.

21.- ¿Cómo podemos detectar un troyano?

R= Inspeccionando frecuentemente la lista de procesos activos en memoria en busca de elementos extraños, vigilar accesos a disco innecesarios.

22.- ¿Qué es un gusano?

R= es un programa auto replicante que no altera los archivos sino que reside en la memoria y se duplica a sí mismo.

23.- ¿Qué es un Hoax?

R= Es un mensaje de correo electrónico con contenido falso o engañoso y normalmente distribuido en cadena.

24.- ¿Cuáles son los objetivos que persigue quien inicia un Hoax?

R= alimentar su ego, captar direcciones de correo y saturar la red o los servidores de correo

25.- ¿Qué es una bomba lógica?

R= es un programa informático que se instala en un ordenador y permanece oculto hasta cumplirse una o más condiciones pre programadas para entonces ejecutar una acción.

26.- ¿Qué diferencia existe entre una bomba lógica y un virus?

R= Que jamás se reproduce por si sola

27.- ¿Menciona algunos ejemplos de condiciones predeterminadas en una bomba lógica?

R= Día de la semana concreto, hora concreta, levantamiento de un interfaz de red concreto.

28.- ¿Ejemplos de acciones en la bomba lógica?

R= Borrar la información del disco duro, mostrar un mensaje, reproducir una canción y enviar un correo electrónico.

29.- ¿Qué es un Spyware (programa espía)?

R= son aplicaciones que recopilan información sobre una persona u organización sin su conocimiento.

30.- ¿Cuál es la función más común que tiene un Spyware?

R= es la de recopilar información sobre el usuario y distribuirlo a empresas publicitarias u otras organizaciones interesadas.

31.- ¿A que pueden tener acceso un Spyware?

R= Al correo electrónico y el password; dirección IP y DNS; teléfono, país; paginas que se visitan, que software está instalado en el equipo, que compras se hacen por internet; tarjetas de crédito y cuentas de banco.

32.- ¿Qué son los cookies?

R= son un conocido mecanismo que almacena información sobre un usuario de internet en su propio ordenador, y se suelen emplear para asignar a los visitantes de un sitio de internet un numero de identificación individual para su reconocimiento subsiguiente.

33.- ¿Para qué se utilizan los robos de datos personales en internet?

R= se utilizan para cometer fraudes financieros. Para obtenerlos, los hackers invaden computadoras y montan sitios falsos en la Web.

34.- ¿Cuál es uno de los principales blancos de ataque?

R= las aplicaciones Web

35.- ¿Menciona otra técnica que se utiliza para el robo de datos personales en internet?

R= es la llamada Phishing, que consiste en conducir al usuario a entrar en un sitio Web falso, que simula, por ejemplo, ser la página de inicio de un banco.

36.- ¿Qué son las infecciones bot?

R= son virus, redes zombies, que alguien te deja en tu maquina, un programa que está latente hasta que alguien le ordena: "hace algo, vamos a atacar el sitio tal".

37.- ¿Qué consideración básica debes tener en cuenta en la seguridad?

R= Que el costo de protección contra un ataque debe ser menor que el valor a perder si un ataque es realizado.

38.- ¿Cómo obtienes una buena calidad en un sistema de información?

R= es necesario revisar la documentación asociada al software con el objetivo de verificar su cobertura, corrección, confiabilidad y facilidad de mantenimiento y también el sistema debe cumplir las especificaciones y requerimientos para su uso y desempeño deseados.

39.- ¿Menciona los niveles de seguridad para el análisis y diseño de los sistemas?

R= Prueba, verificación y validación y certificación

40.- ¿Cómo puede definirse el concepto de prueba?

R= como el proceso de ejecutar un programa con la finalidad de encontrar errores o fallas, los mismos que deben corregirse para dar mayor confiabilidad a un sistema.

41.- ¿Qué tienen en común la prueba con la verificación?

R= Que ambas permiten hallar errores y se realiza al ejecutar un programa en un ambiente simulado.

42.- ¿En qué consiste la validación?

R= en un proceso por el cual se usa un software en un ambiente no simulado, con el fin de encontrar errores que de existir, origina cambios en el sistema.

43.- ¿En qué consiste la certificación?

R= consiste en garantizar que un sistema de información o software determinado este correcto.

44.- ¿Cuál es el motivo de desarrollo el libro naranja (Orange Book)?

R= por la necesidad de evaluar la seguridad, o de tener una medición confiable, es el motivo principal al desarrollar este documento por el gobierno de los E.E.U.U.

45.- ¿Por qué consecuencia surgió el libro naranja?

R= por la consecuencia de la creciente conciencia de la seguridad por parte del gobierno de los E.U. y de la industria, ambos con creciente necesidad de estandarizar el propósito y el uso de las computadoras por el gobierno federal.

46.- ¿Menciona las cuatro extensas divisiones jerárquicas de seguridad del libro naranja?

R= D: Protección mínima C: Protección discrecional B: Protección obligatoria A: Protección controlada.

47.- ¿Cuántas clases contiene la división C?

R= contiene dos distintas clases C1 y C2 (de acuerdo a la nomenclatura adoptada: C2 ofrece una mayor seguridad que C1)

48.- ¿Cuántas clases contiene la división B?

R= contiene tres clases B1, B2 y B3 (B3 ofrece mayor seguridad que B2, y B2 ofrece más seguridad que B1)

49.- ¿Con cuantas clases cuenta la división A?

R= cuenta con una sola clase la A1

50.- ¿A qué se refiere la división D?

R= No hay protección disponible para el hardware; ni identificación de usuario.

51.- ¿Qué nos dice la clase C1?

R= medio de acceso controlado con auditoria. Tienen permisos mas niveles de autorización.

52.- ¿Qué nos dice la clase B1?

R= nivel de protección etiquetada. Objetos bajo control de acceso obligatorio.

53.- ¿Qué nos dice la clase B2?

R= protección estructurada, se etiqueta cada objeto, los dispositivos pueden tener un nivel múltiple de seguridad

54.- ¿A qué se refiere la clase B3?

R= nivel de dominios de seguridad. Requiere una ruta de acceso segura para el usuario.

55.- ¿Qué nos dice la división A?

R= nivel de diseño verificado. Exhaustivo nivel de diseño, verificación y control, supone una distribución confiable de hardware y software.

56.- ¿cuál es el propósito del libro naranja?

R= El criterio de evaluación se desarrolla con 3 objetivos básicos: medición, dirección y adquisición

57.- ¿Qué es el Common Criteria (C.C.)?

R= Es un estándar internacional para seguridad informática

58.- ¿Qué establece el C.C.?

R= establece las bases para evaluar propiedades de seguridad de productos y sistemas de tecnologías de la información.

59.- ¿Menciona las 3 partes que tiene la versión 2.0 del C.C.?

R= 1: introducción y modelo general, 2: requerimientos de seguridad funcional y 3: requerimientos para el aseguramiento de la seguridad.

60.- ¿cuántos niveles de seguridad provee y menciónalos?

R= provee 8 niveles EAL ("Evaluation Assurance Levels")

EAL0: Seguridad inadecuada

EAL1: Funcionamiento testeado

EAL2: Estructuralmente testeado

EAL3: Metodológicamente testeado y chequeado

EAL4: Metodológicamente diseñado, testeado y revisado

EAL5: Semi-formalmente diseñado y testeado

EAL6: Semi-formalmente verificado, diseñado y testeado

EAL7: Formalmente verificado, diseñado y testeado

61.- ¿Cómo proteger una red?

- Computador de entrada a la red interna rigurosamente controlado
- Restricción de funcionalidades
- Soluciones con criptografía

62.- ¿Cuáles son los niveles a analizar (menciona algunos)?

- * Nivel de red
- * Nivel de Gateway
- * Nivel de identificación de MAC address

63.- ¿De qué se trata el ataque de denegación de servicios (DoS)?

R= El intruso intenta evitar que usuarios legítimos accedan a información o servicios.

64.- ¿Cuándo ocurre el ataque más común de denegación de servicio?

R= este ocurre cuando un ataque inunda una red con información

65.- ¿Menciona un ejemplo de ataque de denegación de servicios?

R= cuando una computadora puede procesar un cierto número de solicitudes a la vez, de manera que si un atacante puede sobrecargar al servicio con solicitudes, no podrá procesar mas requerimientos.

66.- ¿Define lo que es un ataque distribuido de denegación de servicios (DDoS)?

R= En este ataque, un atacante puede usar una computadora ajena a él para atacar a un tercero.

67.- ¿Cuáles son las precauciones a tomar para evitar ser víctima de un ataque DoS o DDoS?

R= uso de Firewalls, antivirus actualizados, antispam, etc

68. - ¿Qué es “Source address spoofing”?

R= técnica para obtener acceso no autorizado a un host, a través del cual el intruso envía mensajes a otro host como si procediese de una fuente confiable.

69.- ¿En qué consiste “SYN flooding”?

R= consiste en inundar con pedidos de conexión TCP (SYN) con dirección de retorno invalida al servidor objetivo.

70.- ¿En qué consiste el “Smurf”?

R= consiste en realizar un eco ICMP (ping) a una dirección de broadcast “spoofing” (falsificando) la dirección de origen.

71.- ¿Qué es necesario hacer para evitar formar parte de este tipo de ataque (smurf)?

R= Debe deshabilitarse la opción de redirigir broadcast mediante “no ip directed-broadcast”.

72.- ¿Cuáles son los ataques por ingeniería social?

R= son la práctica de obtener información confidencial a través de la manipulación de usuarios legítimos.

73.- ¿Qué hace un ingeniero social para engañar a la gente?

R= usa comúnmente el teléfono o internet y hace revelar información sensible, o bien a violar las políticas de seguridad típicas.

74.- ¿menciona un ejemplo contemporáneo de un ataque de ingeniería social?

R= es el uso de archivos adjuntos en e-mails que ejecutan código malicioso

75.- ¿Qué causaron los primeros e-mails maliciosos?

R= llevaron a que los proveedores de software deshabilitaran la ejecución automática de archivos adjuntos

76.- ¿Cuál es el ataque de e-mails más simple que aun es efectivo?

R= es engañar a un usuario llevándolo a pensar que uno es un administrador del sistema y solicitando una contraseña para varios propósitos.

77.- ¿Cómo se le llama al tipo de ataque que solicitan contraseña o información de tarjeta de crédito, con el motivo de crear una cuenta?

R= se le llama phishing (pesca)

78.- ¿Quién es uno de los hackers más famosos de los E.U.?

R= Kevin Mitnick

79.- ¿Qué es un Phreaker?

R= Es una persona que interfiere en los sistemas telefónicos, de forma ilegal, mediante el uso de tecnología para poder obtener algún tipo de beneficio como llamadas gratuitas y más.

80.- ¿En qué año se produjo el último arresto de Kevin Mitnick?

R= En 1995, tras ser acusado de entrar en algunos de los ordenadores más seguros de EE.UU.

81.- ¿En qué año fue puesto en libertad Kevin Mitnick?

R= En el 2002

82.- ¿Después de su libertad, a que se dedica Kevin Mitnick?

R= A la consultoría y el asesoramiento en materia de seguridad, a través de su compañía "Mitnick security"

83.- ¿Cuál es el factor determinante de la seguridad de las redes según Kevin Mitnick?

R= Es la capacidad de los usuarios de interpretar correctamente las políticas de seguridad y hacerlas cumplir.

84.- ¿Qué se debe tener en cuenta en las políticas de seguridad?

R= la seguridad debe ser considerada desde la fase de diseño de un sistema, debe darse mayor importancia a la toma de medidas de seguridad, las políticas de seguridad deben ser definidas por los funcionarios de alto nivel.

85.- ¿Que son los encargados de soporte?

R= son aquellos que son responsables de gestionar la seguridad informática en la organización.

86.- ¿Qué medidas deben considerar los encargados de soporte?

R= distribuir las reglas de seguridad, escribir en una lista las reglas básicas de seguridad que los usuarios han de seguir, hacer circular regularmente avisos sobre la seguridad.

87.- ¿Qué describen las normas de seguridad?

R= el modo de funcionamiento de los dispositivos de seguridad y su administración

88.- ¿Qué se podría indicar en una norma de seguridad?

R= todos los usuarios bloquearan su teclado cada vez que dejen sin atención su sistema

89.- ¿Qué normas constituyen un documento fundamental para una empresa que se apoye en computadoras?

R= las normas de personal o de contratación, las normas o políticas de seguridad

90.- ¿Qué se debe tener en cuenta cuando se elabore la política de seguridad?

R= adoctrinar al personal de procesamiento de datos en la importancia de la seguridad y la responsabilidad de cada uno en su mantenimiento

91.- ¿